

Tilington plc — Security Requirements

Cloud Modernisation Programme · Security Baseline

Tilington plc — Security Requirements

Cloud Modernisation Programme | STARTER — v0.1

> Status: INCOMPLETE — Candidate extends in Phase 3

1. Regulatory Security Obligations

FCA / PRA

- SYSC 8 — Outsourcing: AWS is a material outsource, FCA notification required before go-live
- SYSC 13 — Operational risk: Documented controls for IT risk, access management, incident response
- PS21/3 — Operational resilience: Impact tolerances must be met and evidenced

UK GDPR

- Article 32 — Appropriate technical and organisational measures
- Article 25 — Data protection by design and by default
- Article 44 — Restrictions on international transfers

NCSC Cloud Security Principles (All 14 Required)

#	Principle	Status
1	Data in transit protection	TODO
2	Asset protection and resilience	TODO
3	Separation between users	TODO
4	Governance framework	TODO
5	Operational security	TODO
6	Personnel security	TODO
7	Secure development	TODO
8	Supply chain security	TODO
9	Secure user management	TODO
10	Identity and authentication	TODO
11	External interface protection	TODO
12	Secure service administration	TODO

13	Audit information for users	TODO
14	Secure use of the service	TODO

ISO 27001 Domains In Scope

- A.9 — Access control
- A.10 — Cryptography
- A.12 — Operations security
- A.13 — Communications security
- A.14 — System acquisition, development, and maintenance
- A.17 — Information security aspects of BCM

2. Required AWS Security Services

Service	Purpose	Account(s)	Status
AWS CloudTrail	API audit logging	All accounts	TODO: Configure
AWS Config	Resource compliance	All accounts	TODO: Configure
GuardDuty	Threat detection	All accounts	TODO: Enable
Security Hub	Security posture	Security account	TODO: Enable
KMS	Key management	All accounts	TODO: Design CMK strategy
IAM Identity Centre	SSO / federated access	Management account	TODO: Configure
WAF	Web application firewall	Production	TODO: Design ruleset
AWS Shield Standard	DDoS protection	Production	Auto-enabled
Macie	PII discovery in S3	Production	TODO: Configure
Inspector	Vulnerability scanning	Production	TODO: Enable

3. IAM Design Requirements (STARTER — TODO: Candidate completes in Phase 3)

Mandatory IAM Controls

- ☐ No root account access keys
- ☐ Root account MFA enforced via SCP
- ☐ No wildcard (*) IAM permissions except in break-glass role
- ☐ All human access via IAM Identity Centre (SSO)
- ☐ Service accounts use IAM roles, never IAM users
- ☐ Cross-account access via role assumption only, with session conditions

- [] Permission boundary on all developer-created roles

TODO: Define Role Hierarchy

TilingtonAdmin (break-glass) – highest privilege, MFA required, CloudTrail alert
TilingtonPlatformEngineer – TODO: define permissions
TilingtonDeveloper – TODO: define permissions
TilingtonReadOnly – TODO: define permissions
TilingtonSecurityAuditor – TODO: define permissions
TilingtonFinOpsViewer – TODO: define permissions

4. Encryption Requirements

At Rest

- All S3 buckets: SSE-KMS with CMK
- All EBS volumes: KMS encrypted
- All RDS/Aurora: KMS encrypted with separate CMK per environment
- All DynamoDB tables: KMS encrypted

In Transit

- TLS 1.2 minimum everywhere (TLS 1.3 preferred)
- Certificate management via ACM
- No self-signed certificates in production

Key Management

- Separate CMKs for: Production data, Audit logs, Backups, Application secrets
 - Key rotation: automatic annual rotation enabled
 - Key access: least-privilege, logged via CloudTrail
-

5. TODO: Candidate Must Complete

> The following sections are intentionally left incomplete. Complete these in Phase 3.

5.1 Network Security Controls

[CANDIDATE TODO — Define: Security groups design, NACLs policy, WAF rules baseline, VPC Flow Logs configuration]

5.2 NCSC Principles Mapping

[CANDIDATE TODO — Map each of the 14 NCSC Cloud Security Principles to specific AWS controls]

5.3 Incident Response Plan

[CANDIDATE TODO — Define: Detection → Triage → Contain → Eradicate → Recover → Review]

5.4 Penetration Testing Requirements

[CANDIDATE TODO — Define schedule, scope, and methodology per FCA expectations]